LibreriaOnuba-api STRIDE

Propietario: José Angel Lara / Rafael Cordero
Revisor:
Colaboradores:
Generado en fecha: Wed Oct 21 2026

Resumen Ejecutivo

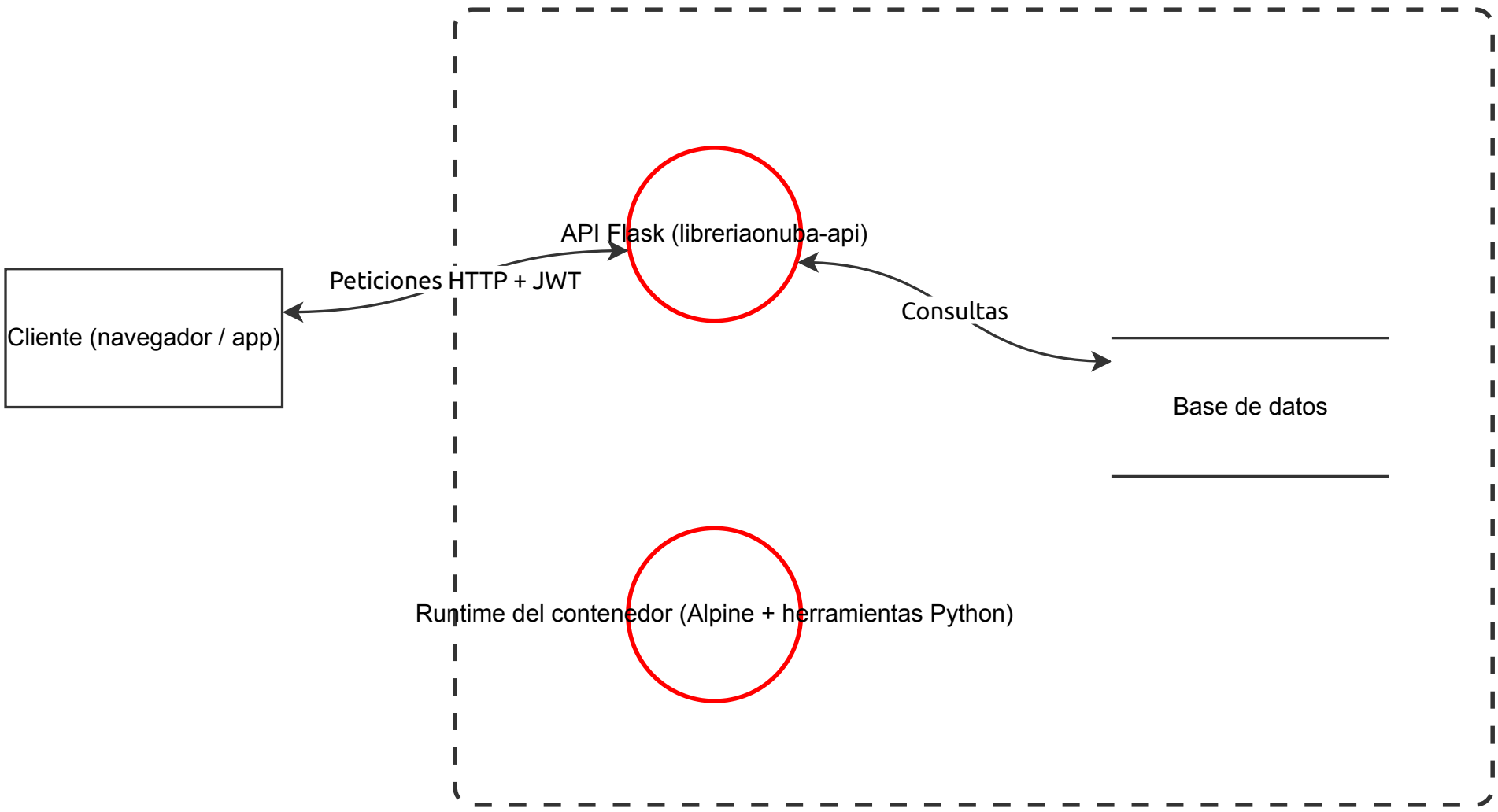
Descripción de alto nivel del sistema (high level system)

Modelo de amenazas generado a partir del informe de Docker Scout de libreriaonuba-api:latest (1 crítica, 15 altas, 21 medias, 3 bajas).

Resumen

Total amenazas	16
Total amenazas mitigadas	0
No Mitigadas	16
Abierto / Crítica Prioridad	0
Abierto / Alta Prioridad	12
Abierto / Prioridad Media	4
Abierto / Baja Prioridad	0

Flujo principal de la API



Flujo principal de la API

Cliente (navegador / app) (Actor)

Descripción: Usuario que consume la API con un JWT.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

API Flask (libreriaonuba-api) (Proceso)

Descripción: Contenedor libreriaonuba-api:latest (linux/arm64, 66 MB, 115 paquetes). Flask + PyJWT.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
1	PyJWT: falsificación de firma JWT (CVE-2026-102268, crítica)	Spoofing	Alta	Abierto		pyjwt 2.6.0 (crítica en el informe de Docker Scout). Verificación de firma incorrecta: un atacante que conozca la clave pública puede forjar tokens HS256 si la lista de algoritmos mezcla HMAC y asimétricos. - CVE-2026-102268 (critical, CVSS 9.1, EPSS 0.196% / 8th percentile): Improper Verification of Cryptographic Signature. Corregido en 2.14.0.	Actualizar pyjwt a >= 2.15.0 (mínimo 2.14.0 para este CVE). Usar una única familia de algoritmos en jwt.decode y no mezclar HS* con RS*/ES*.
2	PyJWT: omisión de verificación de autenticidad/autenticación en tokens	Spoofing	Alta	Abierto		Varias vulnerabilidades de pyjwt 2.6.0 permiten aceptar tokens que deberían rechazarse (cabecera crit, confusión de algoritmos con JWK, etc.). - CVE-2026-32597 (high, CVSS 7.5, EPSS 0.282% / 19th percentile): Insufficient Verification of Data Authenticity. Corregido en 2.12.0. - CVE-2026-48526 (high, CVSS 7.4, EPSS 0.427% / 35th percentile): Improper Authentication. Corregido en 2.13.0. - CVE-2026-102271 (high, CVSS 7.4, EPSS 0.175% / 6th percentile): Improper Verification of Cryptographic Signature. Corregido en 2.14.0. - CVE-2025-45768 (high, CVSS 7.0, EPSS 0.168% / 6th percentile): sin título en el informe. Corregido en . - CVE-2026-102275 (medium, CVSS 6.5, EPSS 0.137% / 3rd percentile): Insufficient Verification of Data Authenticity. Corregido en 2.15.0. - CVE-2026-102269 (medium, CVSS 4.8, EPSS 0.198% / 9th percentile): Incorrect Behavior Order: Validate Before Canonicalize. Corregido en 2.14.0. - CVE-2026-48522 (medium, CVSS 4.2, EPSS 0.220% / 11th percentile): Unintended Proxy or Intermediary ('Confused Deputy'). Corregido en 2.13.0.	Actualizar pyjwt a >= 2.15.0. Fijar algorithms=[...] con un solo algoritmo y validar claims (exp, aud, iss).
3	PyJWT: exposición de información sensible (CVE-2026-102267)	Information disclosure	Alta	Abierto		Exposición de información sensible a un actor no autorizado en pyjwt 2.6.0. - CVE-2026-102267 (high, CVSS 7.4, EPSS 0.157% / 4th percentile): Exposure of Sensitive Information to an Unauthorized Actor. Corregido en 2.14.0.	Actualizar pyjwt a >= 2.15.0 y no incluir datos sensibles en el payload del JWT.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
4	PyJWT: denegación de servicio y fallos de robustez	Denial of service	Media	Abierto		Consumo de recursos sin límite, expresiones regulares ineficientes y excepciones no controladas en pyjwt. - CVE-2026-101918 (medium, CVSS 5.3, EPSS 0.291% / 20th percentile): Uncaught Exception. Corregido en 2.15.0. - CVE-2026-101917 (medium, CVSS 5.3, EPSS 0.354% / 27th percentile): Allocation of Resources Without Limits or Throttling. Corregido en 2.14.0. - CVE-2026-102270 (medium, CVSS 4.4, EPSS 0.192% / 8th percentile): Inefficient Regular Expression Complexity. Corregido en 2.14.0. - CVE-2026-48524 (low, CVSS 3.7, EPSS 0.321% / 23rd percentile): Improper Cleanup on Thrown Exception. Corregido en 2.13.0.	Actualizar pyjwt a >= 2.15.0. Limitar el tamaño de cabeceras/tokens en el proxy inverso o en la API.
5	Werkzeug: ejecución/abuso del depurador por CSRF (CVE-2024-34069)	Elevation of privilege	Alta	Abierto		werkzeug 2.2.3. Es el CVE con mayor EPSS del informe (percentil 88), por lo que es el más probable de ser explotado. - CVE-2024-34069 (high, CVSS 7.5, EPSS 3.397% / 88th percentile): Cross-Site Request Forgery (CSRF). Corregido en 3.0.3.	Actualizar werkzeug a >= 3.1.9. Nunca ejecutar con debug=True en producción ni exponer el depurador.
6	Werkzeug: consumo descontrolado de recursos	Denial of service	Media	Abierto		Cargas de formularios/multipart que agotan CPU o memoria. - CVE-2024-49767 (medium, CVSS 6.9, EPSS 1.095% / 64th percentile): Uncontrolled Resource Consumption. Corregido en 3.0.6. - CVE-2023-46136 (medium, CVSS 5.7, EPSS 1.072% / 64th percentile): Uncontrolled Resource Consumption. Corregido en 2.3.8.	Actualizar werkzeug a >= 3.1.9. Configurar MAX_CONTENT_LENGTH y MAX_FORM_MEMORY_SIZE.
7	Werkzeug: path traversal y nombres de dispositivo de Windows	Information disclosure	Media	Abierto		Acceso a rutas fuera del directorio previsto (send_from_directory/safe_join). Los cuatro CVE de nombres de dispositivo de Windows afectan solo a hosts Windows; la imagen es linux/arm64, así que probablemente no son explotables aquí. - CVE-2024-49766 (medium, CVSS 6.3, EPSS 0.776% / 54th percentile): Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Corregido en 3.0.6. - CVE-2026-27199 (medium, CVSS 6.3, EPSS 0.543% / 44th percentile): Improper Handling of Windows Device Names. Corregido en 3.1.6. - CVE-2026-21860 (medium, CVSS 6.3, EPSS 0.475% / 39th percentile): Improper Handling of Windows Device Names. Corregido en 3.1.5. - CVE-2026-102598 (medium, CVSS 6.3, EPSS 0.368% / 29th percentile): Improper Handling of Windows Device Names. Corregido en 3.1.9. - CVE-2025-66221 (medium, CVSS 6.3, EPSS 0.511% / 42nd percentile): Improper Handling of Windows Device Names. Corregido en 3.1.4.	Actualizar werkzeug a >= 3.1.9. No servir ficheros a partir de rutas controladas por el usuario.
8	Flask: cookie de sesión persistente y caché con datos sensibles	Information disclosure	Alta	Abierto		flask 2.2.2. - CVE-2023-30861 (high, CVSS 8.7, EPSS 1.261% / 69th percentile): Use of Persistent Cookies Containing Sensitive Information. Corregido en 2.2.5. - CVE-2026-27205 (low, CVSS 2.3, EPSS 0.423% / 34th percentile): Use of Cache Containing Sensitive Information. Corregido en 3.1.3.	Actualizar flask a >= 3.1.3 (revisar compatibilidad con Connexion y werkzeug 3). Añadir cabecera Vary: Cookie y cookies Secure/HttpOnly/SameSite.
9	urllib3: certificados mal validados	Spoofing	Alta	Abierto		urllib3 2.7.0: validación incorrecta de certificados en conexiones salientes (suplantación del servidor al que llama la API). - CVE-2026-97687 (high, CVSS 7.6, EPSS 0.242% / 14th percentile): Improper Certificate Validation. Corregido en 2.8.0.	Actualizar urllib3 a >= 2.8.0 y mantener verify=True en las llamadas salientes.
10	urllib3: asignación de recursos sin límite y bucle infinito	Denial of service	Alta	Abierto		urllib3 2.7.0. - CVE-2026-97689 (high, CVSS 8.9, EPSS 0.292% / 20th percentile): Allocation of Resources Without Limits or Throttling. Corregido en 2.8.0. - CVE-2026-97688 (medium, CVSS 6.9, EPSS 0.291% / 20th percentile): Loop with Unreachable Exit Condition ('Infinite Loop'). Corregido en 2.8.0.	Actualizar urllib3 a >= 2.8.0. Establecer timeouts y límites de tamaño en las respuestas.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
11	msgpack: uso de memoria liberada y denegación de servicio	Denial of service	Alta	Abierto		msgpack 1.1.2: dos vulnerabilidades altas al deserializar datos. - GHSA-6v7p-g79w-8964 (high, CVSS 7.5, EPSS /): Use After Free. Corregido en 1.2.1. - CVE-2026-57585 (high, CVSS 7.5, EPSS 0.488% / 40th percentile): sin título en el informe. Corregido en 1.2.1.	Actualizar msgpack a >= 1.2.1. No deserializar datos de origen no confiable.

Runtime del contenedor (Alpine + herramientas Python) (Proceso)

Descripción: Sistema base Alpine y herramientas de build/instalación presentes en la imagen.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
12	setuptools: path traversal y manejo de Unicode	Tampering	Alta	Abierto		setuptools 70.3.0 (y 79.0.1 para el CVE de Unicode). Riesgo al instalar o construir paquetes en el contenedor. - CVE-2025-47273 (high, CVSS 7.7, EPSS 1.539% / 74th percentile): Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Corregido en 78.1.1. - CVE-2026-59890 (medium, CVSS 6.1, EPSS 0.405% / 33rd percentile): Improper Handling of Unicode Encoding. Corregido en 83.0.0.	Actualizar setuptools a >= 83.0.0 y retirar las herramientas de build de la imagen final (multi-stage build).
13	jaraco-context: Zip Slip al extraer tarballs (CVE-2026-23949)	Tampering	Alta	Abierto		jaraco-context 5.3.0 (dependencia de setuptools). - CVE-2026-23949 (high, CVSS 8.6, EPSS 0.618% / 48th percentile): sin título en el informe. Corregido en 6.1.0.	Actualizar jaraco-context a >= 6.1.0 o eliminar setuptools de la imagen final.
14	wheel: path traversal (CVE-2026-24049)	Tampering	Alta	Abierto		wheel 0.45.1. - CVE-2026-24049 (high, CVSS 7.1, EPSS 0.355% / 27th percentile): Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Corregido en 0.46.2.	Actualizar wheel a >= 0.46.2 o excluirlo de la imagen final.
15	pip: path traversal, enlaces y ficheros peligrosos	Tampering	Media	Abierto		pip 24.0 (6 CVEs medios/bajos). - CVE-2025-8869 (medium, CVSS 5.9, EPSS 0.469% / 39th percentile): Improper Link Resolution Before File Access ('Link Following'). Corregido en 25.3. - CVE-2026-13346 (medium, CVSS 5.6, EPSS 0.292% / 20th percentile): Absolute Path Traversal. Corregido en 26.2.0. - CVE-2026-6357 (medium, CVSS 5.3, EPSS 0.171% / 6th percentile): Inclusion of Functionality from Untrusted Control Sphere. Corregido en 26.1. - CVE-2026-3219 (medium, CVSS 4.6, EPSS 0.180% / 7th percentile): Unrestricted Upload of File with Dangerous Type. Corregido en 26.1. - CVE-2026-8643 (medium, CVSS 4.1, EPSS 0.466% / 38th percentile): Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Corregido en 26.1.2. - CVE-2026-1703 (low, CVSS 2.0, EPSS 0.443% / 36th percentile): Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Corregido en 26.0.	Actualizar pip a >= 26.2.0 y no instalar paquetes desde fuentes no confiables.
16	zlib (Alpine): vulnerabilidad alta (CVE-2026-85091)	Denial of service	Alta	Abierto		zlib 1.3.2-r0 en Alpine 3.24. El informe no da CVSS. EPSS 0.592% (percentil 47). - CVE-2026-85091 (high, sin CVSS, EPSS 0.592% / 47th percentile): sin título en el informe. Corregido en 1.3.2-r1.	Reconstruir la imagen con zlib >= 1.3.2-r1 (apk upgrade o imagen base actualizada).

Base de datos (Dispositivo de almacenamiento)

Descripción: Almacén de datos de la API. Supuesto añadido al generar el modelo.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Peticiones HTTP + JWT (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Consultas (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones